Unit 7 Module Wiki: Quantitative Risk Modelling – Techniques, Applications and Limitations

Module: Security and Risk Management (SRM)
Unit: 7 – An Introduction to the Concepts of Quantitative Risk Modelling
Topic: Monte Carlo Simulation, Bayesian Risk Modelling and Multi-Criteria Decision-Making

---

1. Introduction to Quantitative Risk Modelling

Quantitative Risk Modelling (QRM) involves using mathematical models, statistical techniques and numerical data to estimate the likelihood and consequences of uncertain events. In cybersecurity, QRM supports evidence-based decision-making by helping organisations estimate financial losses, compare security investments and prioritise mitigation strategies.

Unlike qualitative risk assessment, which frequently categorises risks as high, medium or low, quantitative approaches aim to express risk using measurable values, including probabilities, monetary losses and expected event frequencies.

The National Institute of Standards and Technology (NIST, 2012) recognises quantitative, qualitative and semi-quantitative approaches to risk assessment. The selection of an appropriate technique depends on the available information, organisational objectives and uncertainty surrounding potential threats.

Three important approaches are probabilistic simulation, Bayesian inference and Multi-Criteria Decision-Making (MCDM).

2. Monte Carlo Simulation

Monte Carlo Simulation is a probabilistic technique that uses repeated random sampling from specified probability distributions to estimate the range and likelihood of possible outcomes.

Rather than depending on a single estimate, the technique produces a distribution of potential losses, enabling organisations to examine both expected and extreme outcomes.

Cybersecurity application

A telecommunications company providing Fibre-to-the-Premises (FTTP) services could use Monte Carlo Simulation to estimate annual financial losses resulting from cyberattacks, network outages, compromised customer routers or unauthorised access to network infrastructure.

The model could include:

- Frequency of successful cyber incidents.
- Financial impact of individual incidents.
- Network restoration costs.

- Customer compensation and service disruption costs.
- Effectiveness of existing security controls.

For example, a company might estimate that cyber incidents occur three times annually, with an average loss of £20,000 per incident. A basic expected annual loss estimate would be £60,000. However, a Monte Carlo model could incorporate uncertainty in both frequency and loss severity, producing a distribution of potential annual losses.

Advantages: Monte Carlo Simulation accommodates uncertainty, supports scenario and sensitivity analysis, and provides decisionmakers with a range of possible financial outcomes.

Limitations: Results depend heavily on input assumptions, the choice of probability distributions and the quality of historical data. Poor assumptions can produce misleading estimates even when thousands of simulations are performed.

Antipattern: Treating simulated outputs as precise predictions or if increasing simulation iterations compensates for unreliable input data.

3. Bayesian Risk Modelling

Bayesian risk modelling applies Bayes' theorem to revise the probability of an event when new evidence becomes available.

Bayes' theorem is expressed as:

$P(A|B) = [P(B|A) \times P(A)] / P(B)$

Where:

- $P(A|B)$ represents the updated probability of event A after observing evidence B.
- $P(B|A)$ represents the probability of observing B if A occurs.
- $P(A)$ represents the initial probability of A.
- $P(B)$ represents the overall probability of evidence B.

Cybersecurity application

Consider an organisation monitoring suspicious login attempts. Initially, the probability of an account being compromised may be estimated at 2%.

Suppose a security alert is generated for 90% of compromised accounts but also for 5% of uncompromised accounts.

Using Bayes' theorem:

$P(\text{Compromise}|\text{Alert}) = (0.90 \times 0.02) / [(0.90 \times 0.02) + (0.05 \times 0.98)]$

= 0.018 / 0.067

= **26.9%**

Although the monitoring system detects 90% of compromised accounts, an individual alert indicates only a 26.9% probability of compromise under these assumptions.

This demonstrates why security teams should consider base rates and false positives rather than automatically treating every alert as evidence of a confirmed attack.

Advantages: Bayesian methods enable continuous updating of risk assessments, integrate prior knowledge with new evidence and support adaptive cybersecurity monitoring.

Limitations: Appropriate prior probabilities can be difficult to establish, and complex Bayesian networks may require substantial computational resources and specialist expertise.

Antipattern: Ignoring the initial probability of an incident, applying subjective priors without justification or treating correlated evidence as independent.

4. Multi-Criteria Decision-Making Approaches

MCDM techniques support decisions involving several potentially competing criteria, such as cost, security effectiveness, operational disruption and implementation complexity.

Three important techniques are:

Analytic Hierarchy Process (AHP): Uses structured pairwise comparisons to establish the relative importance of decision criteria. Saaty (2008) explains that AHP is particularly useful when decisions involve both measurable factors and expert judgements.

Analytic Network Process (ANP): Extends AHP by considering interdependencies and feedback relationships among decision criteria. This makes ANP useful where cybersecurity controls influence one another.

Technique for Order Preference by Similarity to Ideal Solution (TOPSIS): Ranks alternatives according to their relative distance from an ideal solution and a negative-ideal solution (Hwang and Yoon, 1981).

Cybersecurity application

An organisation selecting a cybersecurity solution might compare endpoint detection and response (EDR), security information and event management (SIEM), and managed detection and response (MDR) services.

The assessment could consider detection capability, implementation cost, response time, scalability and staffing requirements.

AHP could establish the importance of each criterion, while TOPSIS could rank alternative solutions according to their weighted performance.

ANP would be more appropriate where criteria have strong interdependencies, such as the relationship between staff expertise, automation and incident response effectiveness.

Advantages: MCDM provides structured, transparent comparisons and supports decisions involving both quantitative and qualitative information.

Limitations: Rankings can be sensitive to subjective weights, normalisation procedures and the criteria selected.

Antipattern: Assigning arbitrary criteria weights, ignoring inconsistent expert judgements or interpreting preference scores as actual probabilities of cyber incidents.

5. Comparative Evaluation

Technique	Main purpose	Strength	Limitation
Monte Carlo	Estimating distributions of possible outcomes	Models' uncertainty and potential losses	Depends on assumptions and input distributions
Bayesian modelling	Updating probabilities using evidence	Supports continuous reassessment	Sensitive to priors and evidence quality
AHP	Weighting criteria and structuring decisions	Transparent pairwise comparisons	Expert judgement can be inconsistent
ANP	Evaluating interdependent criteria	Considers feedback and dependencies	Computationally and conceptually complex
TOPSIS	Ranking alternatives	Relatively straightforward comparison	Sensitive to weighting and normalisation

6. Principles of Effective Quantitative Risk Modelling

The effectiveness of QRM depends on several principles.

Firstly, organisations should clearly define the decision problem, assets, threats, potential consequences and modelling objectives.

Secondly, input data should be supported by credible evidence and documented assumptions. Where reliable information is unavailable, uncertainty should be explicitly acknowledged.

Thirdly, models should undergo validation and sensitivity testing to establish whether reasonable changes in assumptions significantly affect the conclusions.

Finally, numerical outputs should be interpreted within their operational and organisational contexts. A mathematically sophisticated model is not necessarily a reliable model.

7. Critical Reflection and Conclusion

In my view, quantitative risk modelling offers considerable value to cybersecurity risk management, particularly where organisations must justify investment decisions using financial and operational evidence.

Monte Carlo Simulation is suitable for modelling uncertain financial losses, while Bayesian approaches are especially valuable in dynamic environments where security intelligence changes continuously. AHP, ANP and TOPSIS are useful for comparing alternative risk treatment strategies.

However, no individual technique is universally superior. Model selection should reflect the nature of the cybersecurity problem, the availability of reliable evidence and the specific decision being supported.

For FTTP network security, an integrated approach could combine Bayesian modelling to update incident probabilities, Monte Carlo Simulation to estimate potential losses and MCDM to prioritise security improvements.

The central lesson is that quantitative modelling should support professional judgement rather than replace it.

References

Hwang, C.-L. and Yoon, K. (1981) *Multiple Attribute Decision Making: Methods and Applications: A State-of-the-Art Survey*. Berlin: Springer. Available at: https://doi.org/10.1007/978-3-642-48318-9

National Institute of Standards and Technology (NIST) (2012) *Guide for Conducting Risk Assessments*. NIST Special Publication 800-30, Revision 1. Gaithersburg, MD: NIST. Available at: https://doi.org/10.6028/NIST.SP.800-30r1

Saaty, T.L. (2008) 'Decision making with the analytic hierarchy process', *International Journal of Services Sciences*, 1(1), pp. 83–98. Available at: https://doi.org/10.1504/IJSSCI.2008.017590

Ishizaka, A. and Nemery, P. (2013) *Multi-Criteria Decision Analysis: Methods and Software*. Chichester: John Wiley & Sons. Available at: https://doi.org/10.1002/9781118644898